SECSCAN · PANDUAN KESELAMATAN

Pengukuhan Keselamatan WordPress

Panduan praktikal mengukuhkan laman WordPress anda — daripada kata laluan hingga WAF.

Berdasarkan dokumentasi keselamatan rasmi WordPress, dipetakan kepada semakan automatik yang SecScan lakukan pada laman anda.

Edisi 2026 · Bahasa Melayu

Pengenalan

WordPress menguasai sebahagian besar web, dan itu menjadikannya sasaran utama. Menurut data ekosistem 2024, kira-kira 96% kelemahan yang dilaporkan datang daripada **plugin dan tema**, bukan teras WordPress. Maka pengukuhan bukan sekali-sekala — ia amalan berterusan.

Panduan ini meringkaskan amalan terbaik daripada *Hardening WordPress* (handbook rasmi WordPress.org) dan memetakannya kepada semakan automatik yang dilakukan SecScan pada laman anda.

Bagaimana SecScan membantu

SecScan mengimbas laman anda secara luaran (black-box) dan mengesan WordPress secara automatik. Bila WordPress dikesan, SecScan turut menyemak CVE terkini berkaitan teras dan sambungan, sijil TLS, header keselamatan, fail terdedah, dan konfigurasi DNS/e-mel. Panduan ini menerangkan cara membetulkan setiap isu yang SecScan mungkin laporkan.

1. Kemas kini teras, plugin & tema

Versi lama tidak lagi menerima tampung keselamatan. Apabila kelemahan didedahkan, maklumat untuk mengeksploitnya biasanya sudah tersebar — jadi versi lama paling mudah diserang.

Hidupkan kemas kini automatik untuk teras, dan padam plugin/tema yang tidak digunakan sepenuhnya (bukan sekadar nyahaktif). Muat turun hanya dari repositori WordPress.org atau vendor yang dipercayai.

- Hidupkan auto-update teras (sejak WP 3.7).
- Padam plugin/tema tidak aktif — ia tetap boleh dieksploit.
- Jangan sekali-kali muat turun WordPress dari laman selain wordpress.org.

2. Kata laluan kukuh & pengesahan 2 langkah

Kata laluan kukuh ialah pertahanan asas terhadap serangan brute-force. Elakkan nama sebenar, nama syarikat/laman, perkataan kamus, atau kata laluan pendek.

Aktifkan pengesahan dua faktor (2FA) — wajib untuk semua akaun Editor dan Administrator.

- Guna kata laluan unik ≥ 12 aksara, campuran huruf & nombor.
- Wajibkan 2FA untuk semua akaun keistimewaan tinggi.
- Tukar nama pengguna 'admin' kepada yang tidak mudah diteka.

3. Kukuhkan wp-config.php

Fail wp-config.php mengandungi tetapan paling sensitif. Halang akses terus kepadanya dan matikan editor fail terbina supaya penyerang yang berjaya log masuk tidak boleh menyunting PHP terus dari dashboard.

- Matikan penyuntingan fail dari dashboard.
- Halang akses HTTP terus ke wp-config.php melalui .htaccess.
- Tukar table_prefix lalai 'wp_' untuk menyukarkan SQL-injection automatik.

```
// dalam wp-config.php
define( 'DISALLOW_FILE_EDIT', true );

# dalam .htaccess
<Files "wp-config.php">
Require all denied
</Files>
```

4. Keizinan fail yang betul

Kunci keizinan fail seketat mungkin. Skema lazim: direktori 755, fail 644. Elakkan keizinan 'world-writable' (mod yang berakhir dengan 6 atau 7 pada digit terakhir) pada fail teras.

- Direktori: 755 · Fail: 644.
- wp-admin/, wp-includes/, plugins/ hanya boleh ditulis oleh akaun anda.
- Guna SFTP (bukan FTP) supaya kata laluan tidak dihantar dalam bentuk terang.

```
find /path/wordpress/ -type d -exec chmod 755 {} \;
find /path/wordpress/ -type f -exec chmod 644 {} \;
```

5. Lindungi wp-admin & wp-includes

Tambah lapisan kedua pada kawasan admin (contoh BasicAuth atau hadkan mengikut IP), dan sekat skrip dalaman wp-includes yang tidak sepatutnya diakses terus. Wajibkan HTTPS untuk semua sesi admin.

- Wajibkan HTTPS/SSL untuk log masuk & admin.
- Sekat skrip include-only melalui mod_rewrite (letak di luar tag # BEGIN WordPress).
- Pertimbang hadkan wp-login.php mengikut IP jika boleh.

6. Firewall (WAF) & pemantauan

Firewall aplikasi web (WAF) menapis serangan sebelum ia diproses WordPress — sama ada di peringkat plugin, pelayan (ModSecurity), atau sebagai reverse-proxy (Cloudflare/Sucuri).

Log ialah kawan terbaik untuk forensik: ia mendedahkan percubaan XSS, RFI/LFI, directory traversal, dan brute-force. Pantau perubahan fail dengan alat seperti OSSEC.

- Pasang WAF (peringkat plugin, pelayan, atau reverse-proxy).
- Simpan & pantau access_log / error_log.
- Pantau integriti fail — amaran automatik bila fail .php berubah.

7. Sandaran & pemulihan

Sandaran ialah jaring keselamatan terakhir. Simpan snapshot berkala (fail teras + pangkalan data) di lokasi dipercayai. Snapshot sebelum-kompromi membolehkan anda membina semula laman, snapshot selepas-kompromi membantu memahami cara serangan berlaku.

- Backup berjadual (fail + pangkalan data), diuji secara berkala.
- Simpan rekod bebas hash MD5 setiap fail backup.

- Hadkan keistimewaan pengguna MySQL kepada SELECT/INSERT/UPDATE/DELETE untuk operasi biasa.

Pemetaan: semakan SecScan → tindakan anda

Jadual di bawah memetakan setiap kategori semakan SecScan kepada tindakan pengukuhan WordPress yang berkaitan. Jalankan scan di laman SecScan, kemudian rujuk baris yang sepadan.

Semakan SecScan	Kaitan dengan keselamatan CMS anda
Technology / CVE	Mengesan WordPress & versinya, kemudian menyenaraikan CVE teras/plugin terkini dari suapan NVD. Padankan dengan plugin yang anda pasang dan kemas kini segera.
TLS/SSL	Menyemak sijil, versi protokol & cipher. Pastikan HTTPS wajib untuk wp-admin dan seluruh laman.
Headers	Menyemak HSTS, CSP, X-Frame-Options, X-Content-Type-Options — mengurangkan risiko clickjacking & XSS pada dashboard.
Exposed Files	Mengesan fail terdedah seperti wp-config.php, backup, atau readme yang membocorkan versi. Halang akses terus.
Information Leakage	Mengesan tag generator/versi yang membantu penyerang. Buang atau kaburkan maklumat versi.
DNS / Transport	Menyemak SPF/DMARC dan pengukuhan pengangkutan e-mel — penting jika laman menghantar e-mel notifikasi.
Cookies	Menyemak atribut Secure/HttpOnly/SameSite pada kuki sesi — melindungi kuki pengesahan WordPress.

Senarai semak pantas

Cetak dan tandakan setiap item sebagai audit minimum:

- ■ Teras, semua plugin & tema dikemas kini ke versi terkini
- ■ Plugin/tema tidak digunakan telah dipadam
- ■ 2FA diaktifkan untuk semua akaun Administrator/Editor
- ■ Kata laluan unik ≥ 12 aksara untuk setiap akaun
- ■ DISALLOW_FILE_EDIT diset dalam wp-config.php
- ■ Akses HTTP ke wp-config.php disekat
- ■ Keizinan fail 644 / direktori 755 disahkan
- ■ HTTPS diwajibkan untuk seluruh laman
- ■ WAF atau plugin keselamatan dipasang & aktif
- ■ Backup berjadual berjalan dan telah diuji pulih
- ■ Scan SecScan dijalankan dan semua isu Kritikal diselesaikan

Nota: keselamatan ialah pengurangan risiko, bukan penghapusan risiko. Kekalkan sandaran (backup) yang diuji dan kemas kini kerap. Panduan ini bahan rujukan — sahkan setiap arahan pada persekitaran anda.